



STUDENT DETAILS

Name: Job Roman Barasa

Admission Number: BSCCS/2024/42922

Course: Bachelor of Science in Computer Science

Unit Code: BIT 4139

Unit Name: Ethical Hacking and Counter Measures

Lecturer Name: Michael Nyoro

Academic Year: 4, Semester 1

PROJECT DETAILS

Project Title: Ethical Hacking and Countermeasures Logbook Week 1 to 7

Selected Technologies

- Nmap
- Zenmap
- Whois
- Wappalyzer
- DNSDumpster

Github Link: [Link](#)

Contents

Week 1	4
Kali Linux Setup and Installation	4
Week 2: Penetration Testing Basics	6
Tasks.....	6
Screenshots	6
Week 3, 4 and 5	9
Task 1: Information Gathering.....	9
Target Identification.....	9
Domain Information	9
IP Address Identification.....	10
Subdomains.....	10
Technology Used	13
Open Services Enumeration	14
Task 2: Scanning and Enumeration	15
Scan Ports.....	15
Detect Running Services.....	16
Identify OS Version.....	17
Shared Folders	17
Reflection.....	17
Week 6: Vulnerability Assessment and Scanning.....	18
Demo 1: Basic Network Discovery	18
Demo 2: Service Version Detection.....	19
.....	19
Demo 3: Vulnerability Information Research.....	19

Class Activity 1: Vulnerability Identification	20
Week 7: Web Application Security and OWASP Top 10.....	24
Class Demonstration 1: HTTP Request Analysis	24
Class Demonstration 2: Input Validation Testing	26
Class Demonstration 3: Cookie Security Analysis	27
Class Demonstration 4: Web Application Mapping	28
Class Activity 1: Vulnerability Identification Exercise	30
Results	31
Class Activity 2: Risk Classification	32
Class Activity 3: Secure Design Discussion.....	32
Practical Task 1: OWASP Top 10 Research.....	33
Practical Task 2: Web Application Assessment	36
Practical Task 3: Security Improvement Proposal.....	38

Week 1

Kali Linux Setup and Installation

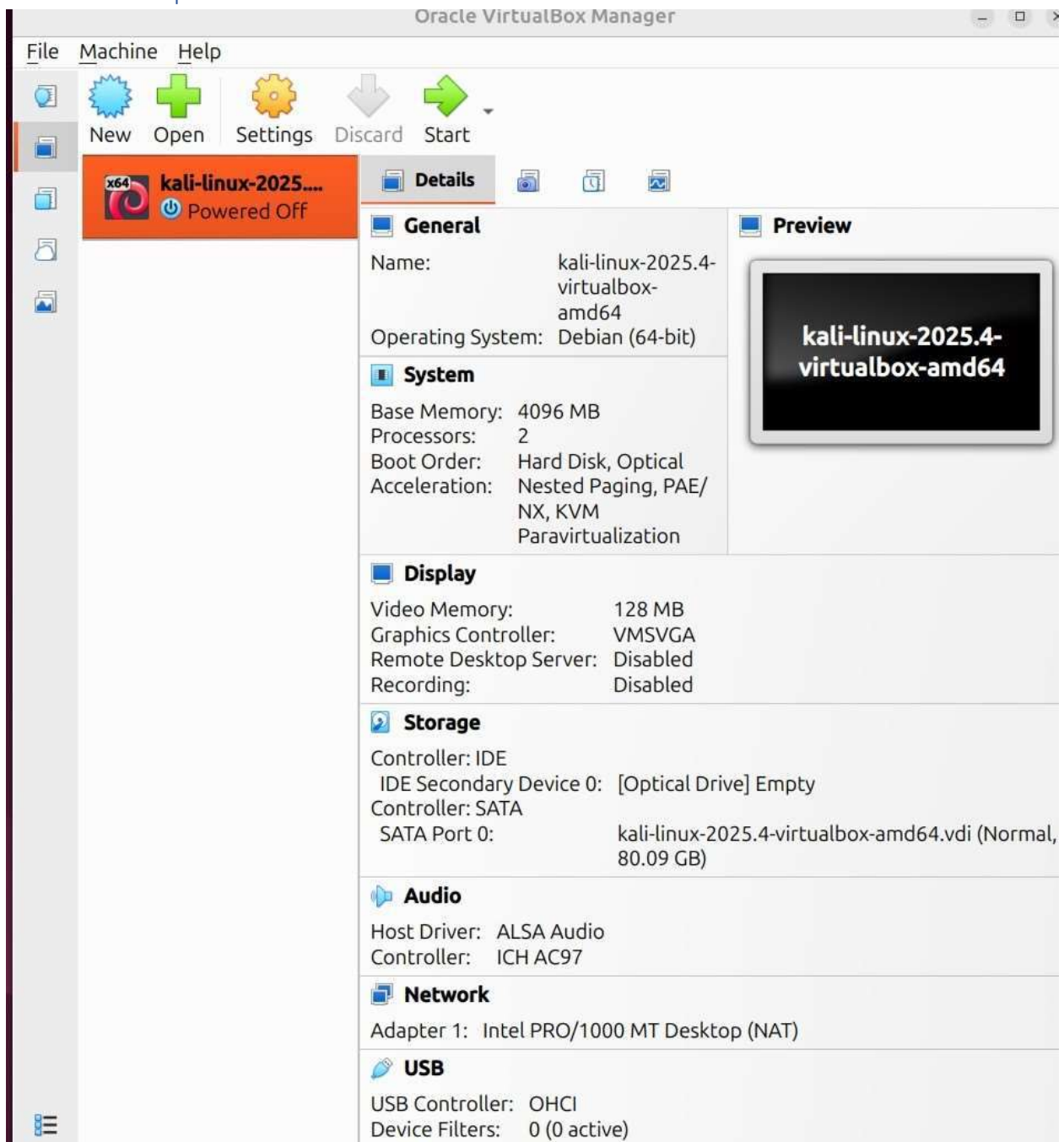


Figure 1 Virtual Box Home Page With the Kali ISO



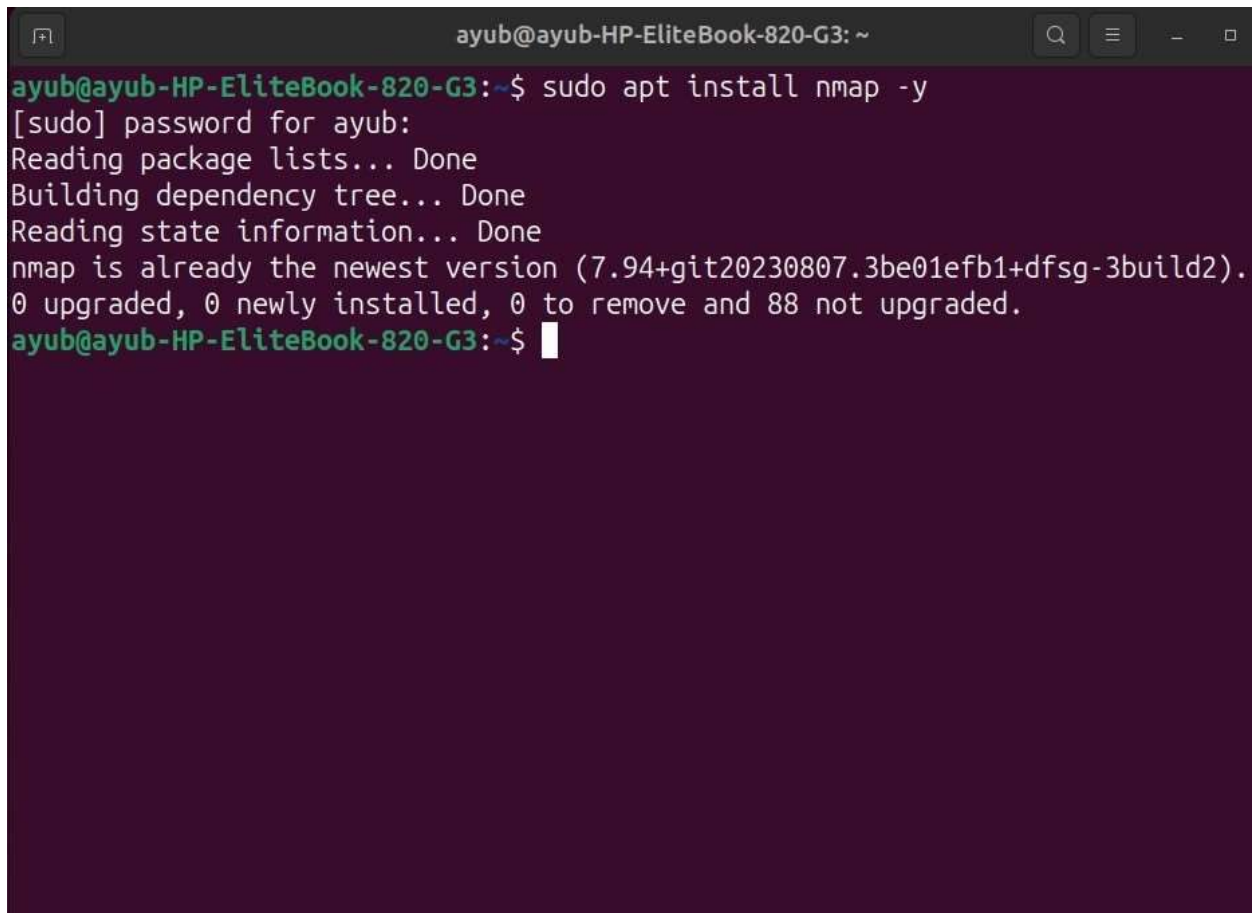
Figure 2 Up and Running Kali Linux With All Tools Configured:

Week 2: Penetration Testing Basics

Tasks

1. Scan for vulnerabilities, check for weak passwords, old systems with no hashes.
2. Generate report
3. Footprinting
4. Scanning networks

Screenshots

A terminal window with a dark purple background. The title bar at the top reads 'ayub@ayub-HP-EliteBook-820-G3: ~'. The terminal shows the command 'sudo apt install nmap -y' being executed. The output indicates that nmap is already the newest version (7.94+git20230807.3be01efb1+dfsg-3build2) and that 0 packages were upgraded, 0 newly installed, 0 to remove, and 88 not upgraded. The prompt returns to the user's shell.

```
ayub@ayub-HP-EliteBook-820-G3:~$ sudo apt install nmap -y
[sudo] password for ayub:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
nmap is already the newest version (7.94+git20230807.3be01efb1+dfsg-3build2).
0 upgraded, 0 newly installed, 0 to remove and 88 not upgraded.
ayub@ayub-HP-EliteBook-820-G3:~$
```

Figure 1 Installation of Nmap



Figure 2: Basic Scan Using nmap

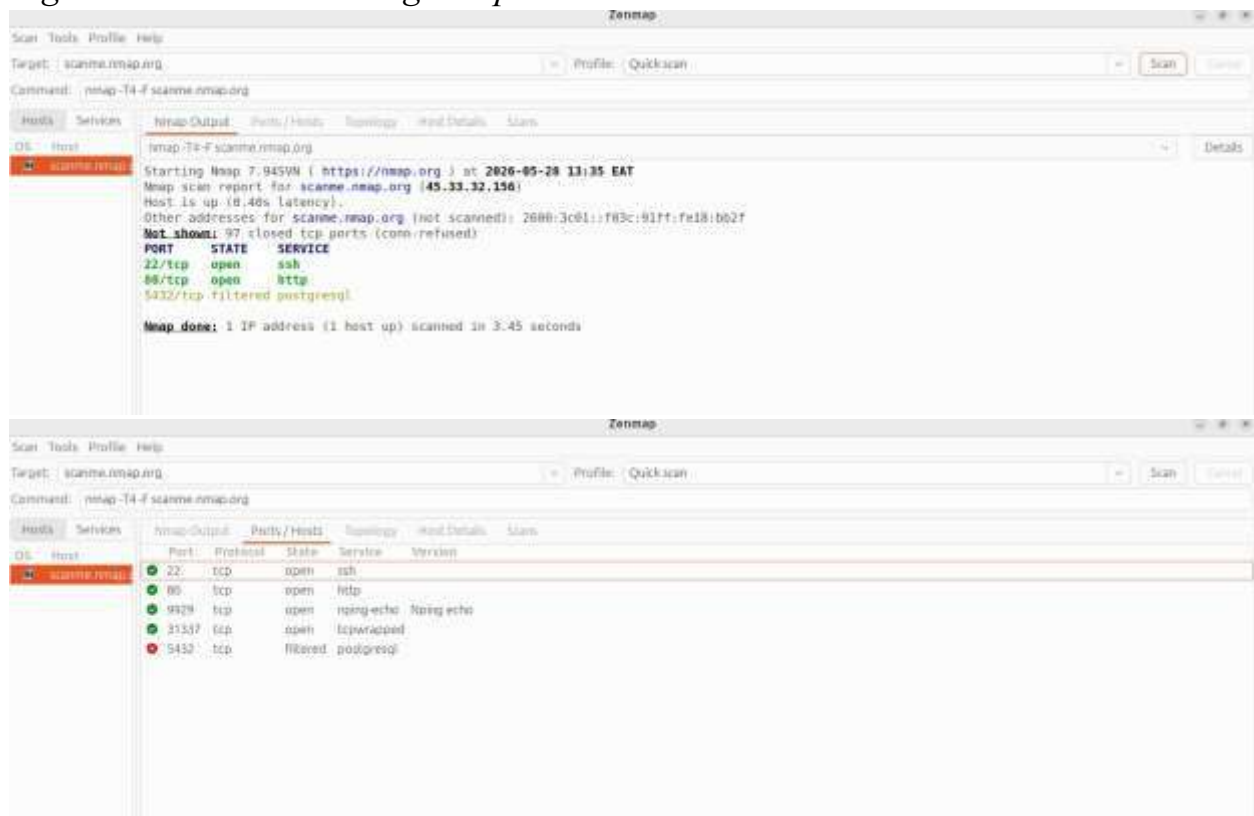


Figure 3: Port Scan

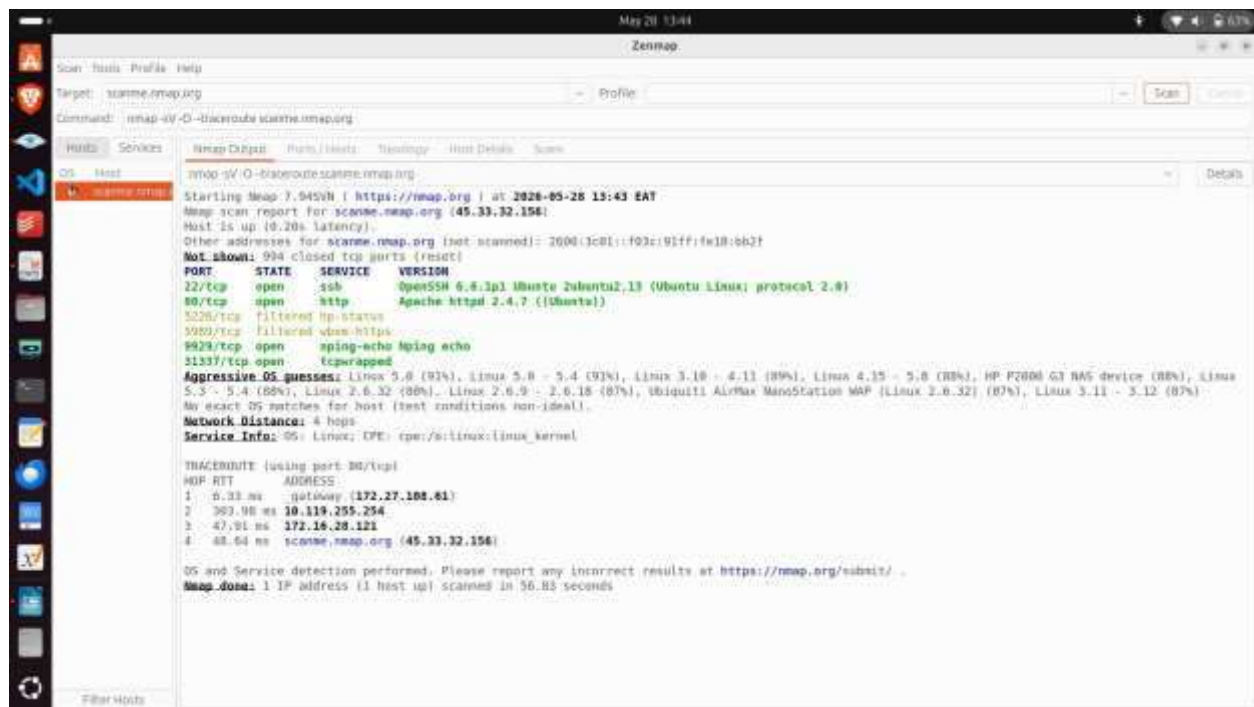


Figure 4: Footprinting

Week 3, 4 and 5

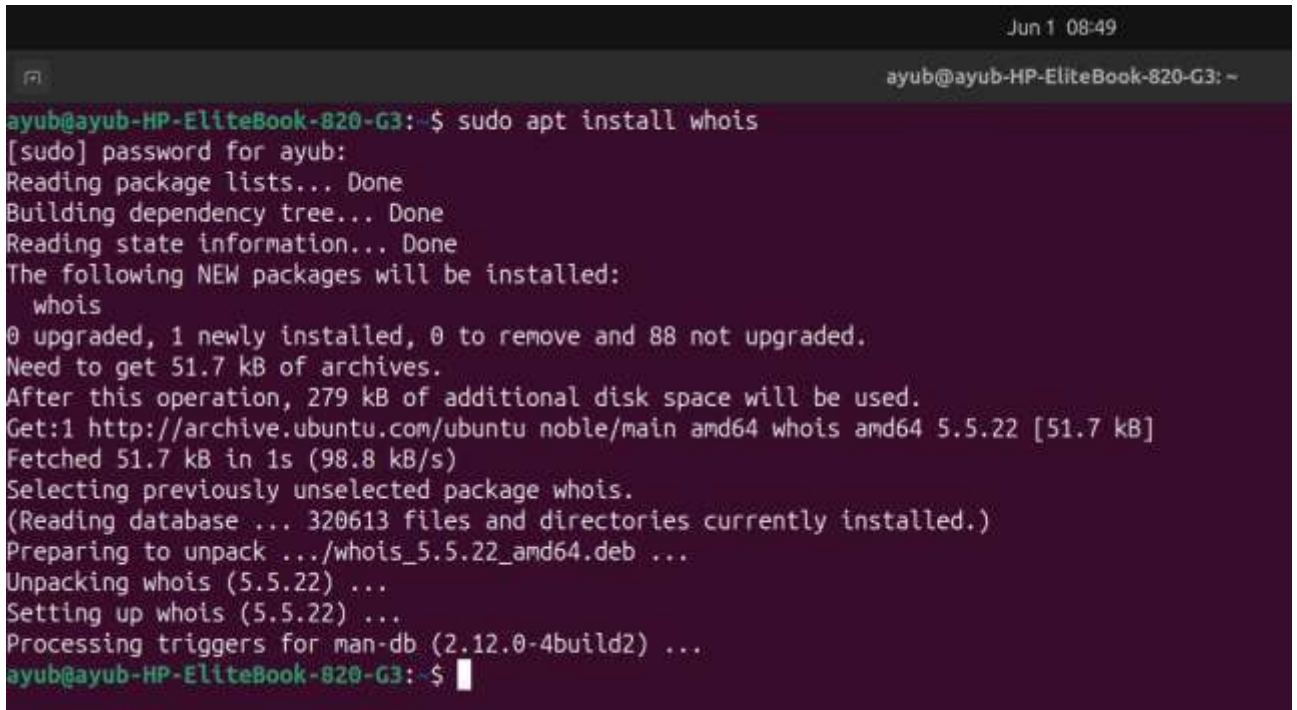
Task 1: Information Gathering

Target Identification

Selected Organization: Machakos Institute of Technology (MIT)

Website: <https://www.mit.ac.ke/>

Domain Information

A terminal window with a dark purple background and white text. The window title bar shows 'Jun 1 08:49' and 'ayub@ayub-HP-EliteBook-820-G3: ~'. The terminal content shows a user running 'sudo apt install whois'. The output includes: '[sudo] password for ayub:', 'Reading package lists... Done', 'Building dependency tree... Done', 'Reading state information... Done', 'The following NEW packages will be installed: whois', '0 upgraded, 1 newly installed, 0 to remove and 88 not upgraded.', 'Need to get 51.7 kB of archives.', 'After this operation, 279 kB of additional disk space will be used.', 'Get:1 http://archive.ubuntu.com/ubuntu noble/main amd64 whois amd64 5.5.22 [51.7 kB]', 'Fetched 51.7 kB in 1s (98.8 kB/s)', 'Selecting previously unselected package whois.', '(Reading database ... 320613 files and directories currently installed.)', 'Preparing to unpack .../whois_5.5.22_amd64.deb ...', 'Unpacking whois (5.5.22) ...', 'Setting up whois (5.5.22) ...', 'Processing triggers for man-db (2.12.0-4build2) ...', and finally 'ayub@ayub-HP-EliteBook-820-G3: \$' with a cursor.

```
ayub@ayub-HP-EliteBook-820-G3:~$ sudo apt install whois
[sudo] password for ayub:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following NEW packages will be installed:
  whois
0 upgraded, 1 newly installed, 0 to remove and 88 not upgraded.
Need to get 51.7 kB of archives.
After this operation, 279 kB of additional disk space will be used.
Get:1 http://archive.ubuntu.com/ubuntu noble/main amd64 whois amd64 5.5.22 [51.7 kB]
Fetched 51.7 kB in 1s (98.8 kB/s)
Selecting previously unselected package whois.
(Reading database ... 320613 files and directories currently installed.)
Preparing to unpack .../whois_5.5.22_amd64.deb ...
Unpacking whois (5.5.22) ...
Setting up whois (5.5.22) ...
Processing triggers for man-db (2.12.0-4build2) ...
ayub@ayub-HP-EliteBook-820-G3:~$
```

Figure 1: Installation of WHOis

```
ayub@ayub-HP-EliteBook-820-G3:~$ whois mit.ac.ke
Domain Name: mit.ac.ke
Registry Domain ID: 12326-Kenic
Registrar WHOIS Server: https://hostafrica.com
Registrar URL: https://hostafrica.com
Updated Date: 2026-01-15T08:09:52Z
Creation Date: 2008-02-05T21:00:00Z
Registry Expiry Date: 2027-02-05T21:00:00Z
Registrar Registration Expiration Date: 2027-02-05T21:00:00Z
Registrar: HOSTAFRICA EAC
Registrar Street Address: NEXTGEN MALL 5th FLOOR Office NO. 14
MOMBASA ROAD NAIROBI
P.O. Box 3543 - 00200 Nairobi
Registrar City: Nairobi
Registrar State: Nairobi
Registrar Postal Code: 001000
Registrar Phone: 0709399000
Registrar Email: noreply@hostafrica.com
Registrar Abuse Contact Email: support@hostafrica.com
Registrar Abuse Contact Phone:
Domain Status: active https://icann.org/epp#active
Domain Status: serverRenewProhibited https://icann.org/epp#serverRenewProhibited
Domain Status: serverTransferProhibited https://icann.org/epp#serverTransferProhibited
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Name Server: ns2.host-ww.net
Name Server: ns1.host-ww.net
DNSSEC: unsigned
>>> Last update of WHOIS database: 2026-06-01T05:51:24.733Z <<<

For more information on domain status codes, please visit https://icann.org/epp
```

Figure 2: Obtain Domain Information Using WHOIs

IP Address Identification

```
ayub@ayub-HP-EliteBook-820-G3:~$ nslookup mit.ac.ke
Server:          127.0.0.53
Address:         127.0.0.53#53

Non-authoritative answer:
Name:   mit.ac.ke
Address: 102.218.215.23
```

Figure 3: IP Address Identification

Subdomains

A site called DNSDumpster was used to get a list of all subdomains present

4 Records (subdomains from dataset)

Host	IP	ASN	ASN Name	Open Services (from DB)	RevIP
app.mt.ac.ke	102.218.215.23 102.218.215.23	129184 102.218.215.8/24	Rest Africa (Pty) Ltd - Rest Africa (Pty) Ltd, ZA South Africa		2641
www.app.mt.ac.ke	102.218.215.23 102.218.215.23	129184 102.218.215.8/24	Rest Africa (Pty) Ltd - Rest Africa (Pty) Ltd, ZA South Africa		2641
campussphere.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France		14
www.campussphere.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France		14
opcalendars.mt.ac.ke	102.218.215.23 102.218.215.23	129184 102.218.215.8/24	Rest Africa (Pty) Ltd - Rest Africa (Pty) Ltd, ZA South Africa		2641
opcontacts.mt.ac.ke	102.218.215.23 102.218.215.23	129184 102.218.215.8/24	Rest Africa (Pty) Ltd - Rest Africa (Pty) Ltd, ZA South Africa		2641
exams.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France		14
www.exams.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France		14

Figure 4: Subdomain List 1

staff.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France	14
www.staff.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France	14
students.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France	14
www.students.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France	14
verify.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France	14
www.verify.mt.ac.ke	38.242.235.241 38.242.235.241	51187 38.242.224.8/19	CONTABO - Contabo GmbH, DE France	14
webdisk.mt.ac.ke	102.218.215.23 102.218.215.23	129184 102.218.215.8/24	Rest Africa (Pty) Ltd - Rest Africa (Pty) Ltd, ZA South Africa	2641
webmail.mt.ac.ke	102.218.215.23 102.218.215.23	129184 102.218.215.8/24	Rest Africa (Pty) Ltd - Rest Africa (Pty) Ltd, ZA South Africa	2641

MX Records

Figure 5: Subdomain List 2

Technology stack

CMS



Blogs



Programming languages

 [PHP](#) (7.4.33)

Databases



Web servers



Figure 8: Wappalyzer screen showing all technologies used for the website

Locale
Countries
Kenya

Security
Certificate protocol
TLS 1.3
Certificate expiry
Jul 16, 2026
SPF record
✓
DMARC record
✓

Figure 9: Wappalyzer image showing more details on technology used

Open Services Enumeration

You can do the following without logging in:

- View home page
- View list of courses
- Access enrollment section and download application form
- View images of previous events
- Get links to respective student or staff portals
- Obtain contact information

Task 2: Scanning and Enumeration

Scan Ports

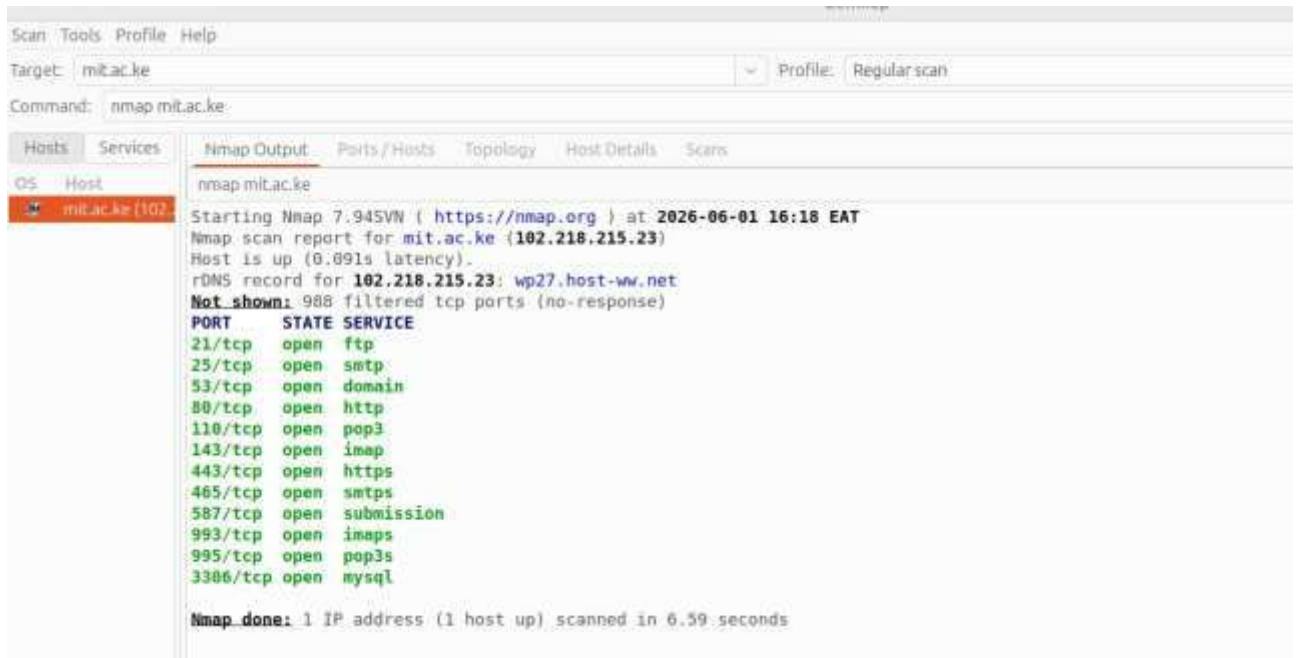


Figure 10: Regular nmap port scan

Detect Running Services

```
ayub@ayub-HP-EliteBook-820-G3:~$ nmap -sV mit.ac.ke
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-01 16:21 EAT
Nmap scan report for mit.ac.ke (102.218.215.23)
Host is up (0.094s latency).
rDNS record for 102.218.215.23: wp27.host-ww.net
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Pure-FTPd
25/tcp    open  smtp?
53/tcp    open  domain       PowerDNS Authoritative Server 4.9.5
80/tcp    open  http         LiteSpeed httpd
110/tcp   open  pop3         Dovecot pop3d
143/tcp   open  imap         Dovecot imapd
443/tcp   open  ssl/http     LiteSpeed httpd
465/tcp   open  ssl/smtp     Exim smtpd 4.99.2
587/tcp   open  smtp         Exim smtpd 4.99.2
993/tcp   open  ssl/imap     Dovecot imapd
995/tcp   open  ssl/pop3     Dovecot pop3d
3306/tcp   open  mysql        MySQL 5.5.5-10.6.25-MariaDB-cll-lve

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 176.85 seconds
ayub@ayub-HP-EliteBook-820-G3:~$
```

Figure 11: Identification of running services

Identify OS Version

```
ayub@ayub-HP-ElliteBook-820-G3: ~$ sudo nmap -O mit.ac.ke
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-01 16:28 EAT
Nmap scan report for mit.ac.ke (102.218.215.23)
Host is up (0.071s latency).
rDNS record for 102.218.215.23: wp27.host-ww.net
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
443/tcp   open  https
465/tcp   open  smtps
587/tcp   open  submission
993/tcp   open  imaps
995/tcp   open  pop3s
3306/tcp  open  mysql
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: game console|media device
Running (JUST GUESSING): Microsoft embedded (87%), Sling embedded (85%)
Aggressive OS guesses: Microsoft Xbox game console (modified, running XboxMediaCenter) (87%), Slingbox Pro-HD TV over
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.22 seconds
```

Figure 12: Attempts of identifying the version of OS used

Shared Folders

No SMB services were detected and thus shared folder enumeration could not be performed

Reflection

Through this task I gained hands on experience in scanning techniques used in penetration testing. The exercise helped me understand the importance of information gathering and the potential security risks associated with exposed services and info that is publicly available

Week 6: Vulnerability Assessment and Scanning

Demo 1: Basic Network Discovery

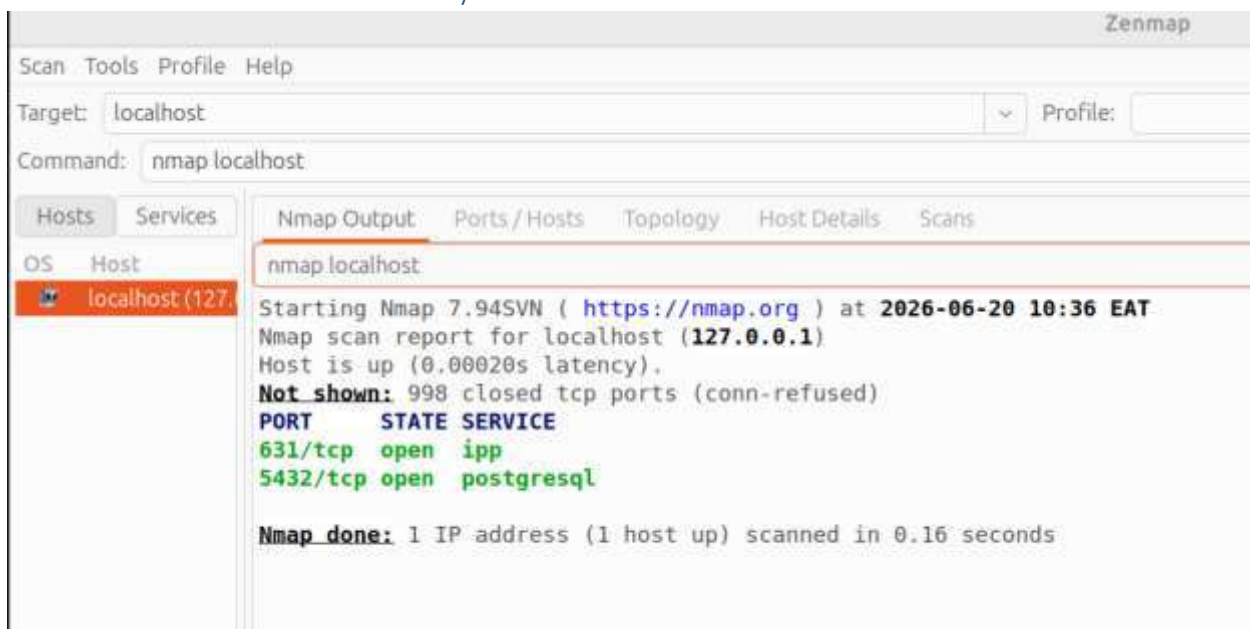


Figure 2: Zenmap scan 1 showing open ports and services

Demo 2: Service Version Detection



Figure 3: Running services and software versions

Demo 3: Vulnerability Information Research

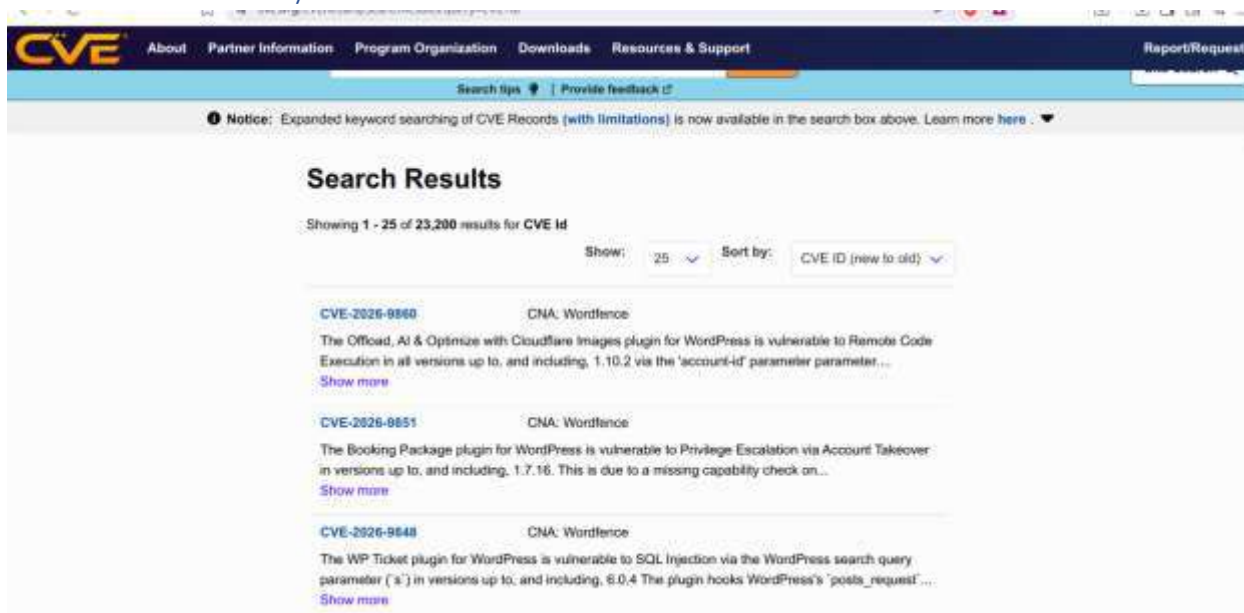


Figure 4: A list of some recorded known vulnerabilities available on CVE

Class Activity 1: Vulnerability Identification

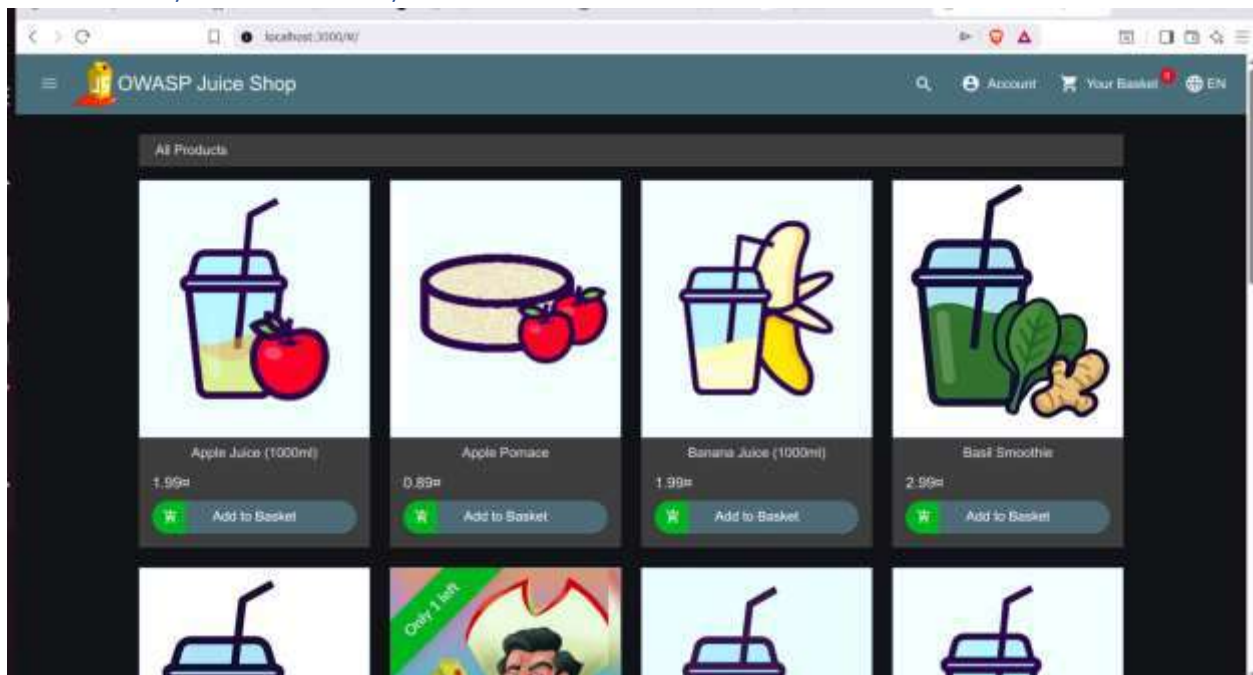
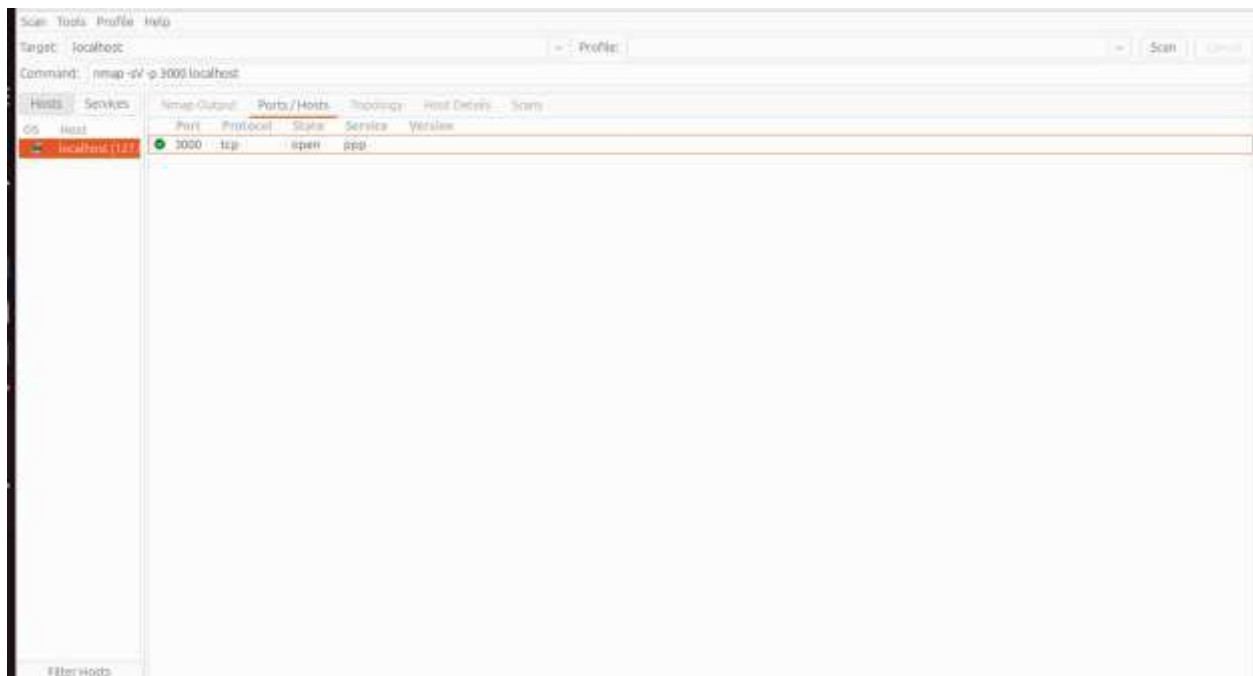


Figure 5: Target website



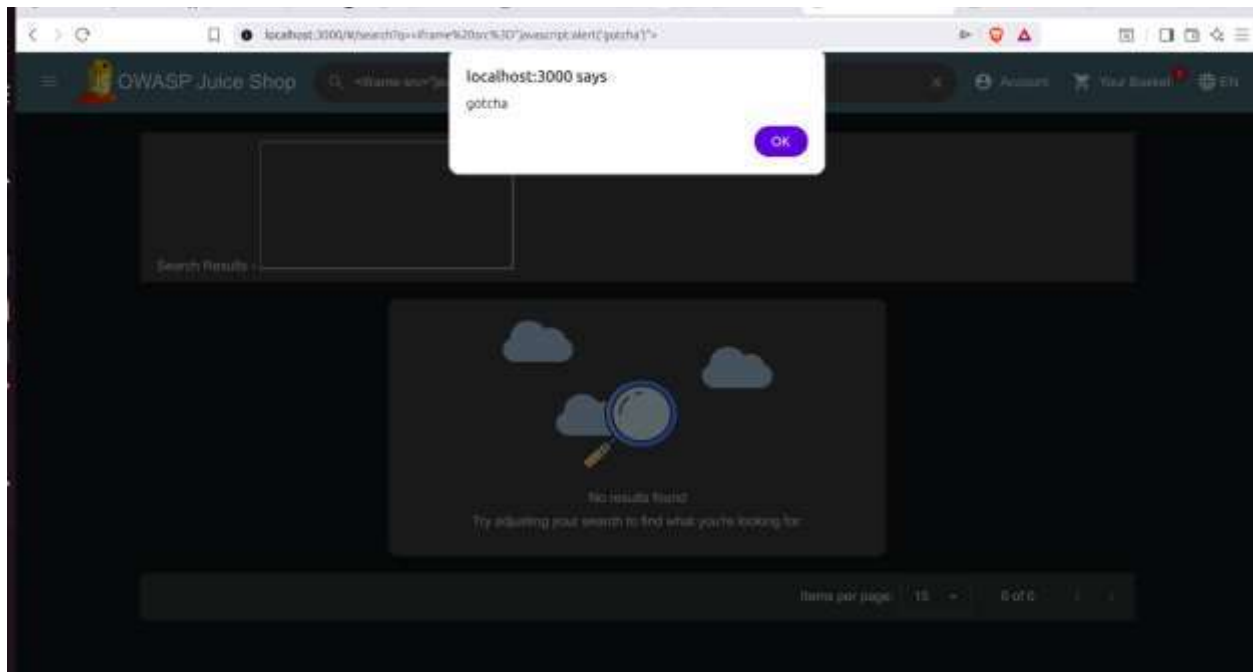


Figure 6: Cross Site Scripting attempt

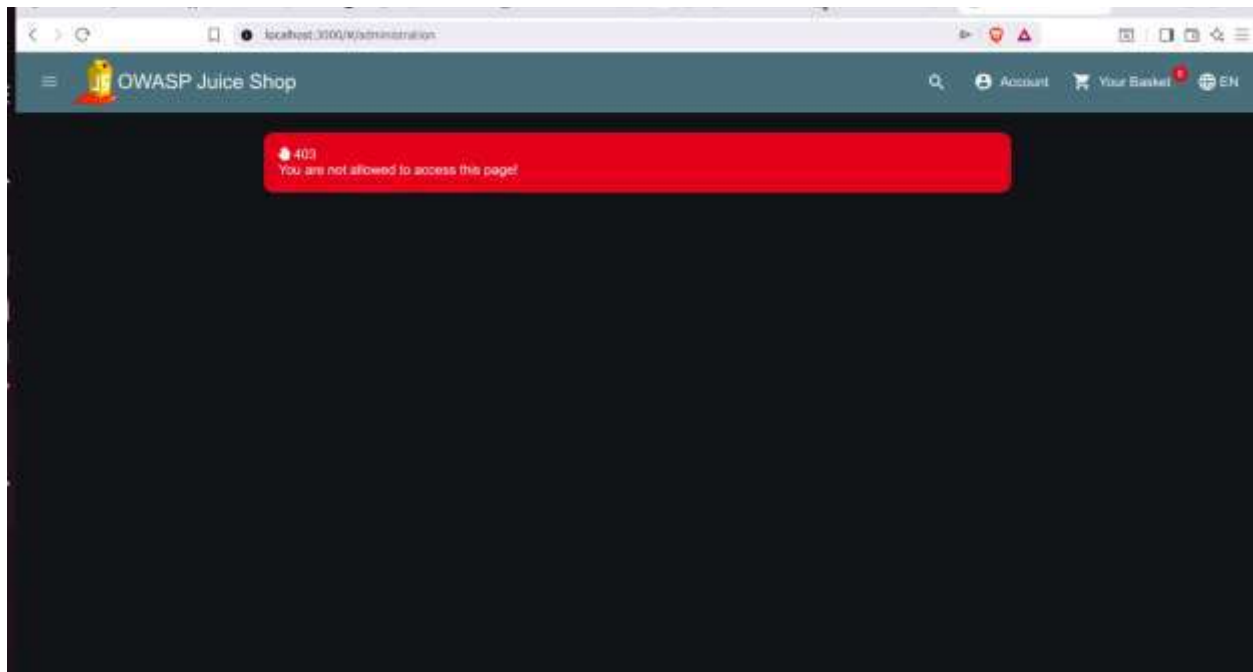


Figure 7: Attempted access to restricted administrative panel demonstrating access control behavior.

Class Demonstration 1: HTTP Request Analysis

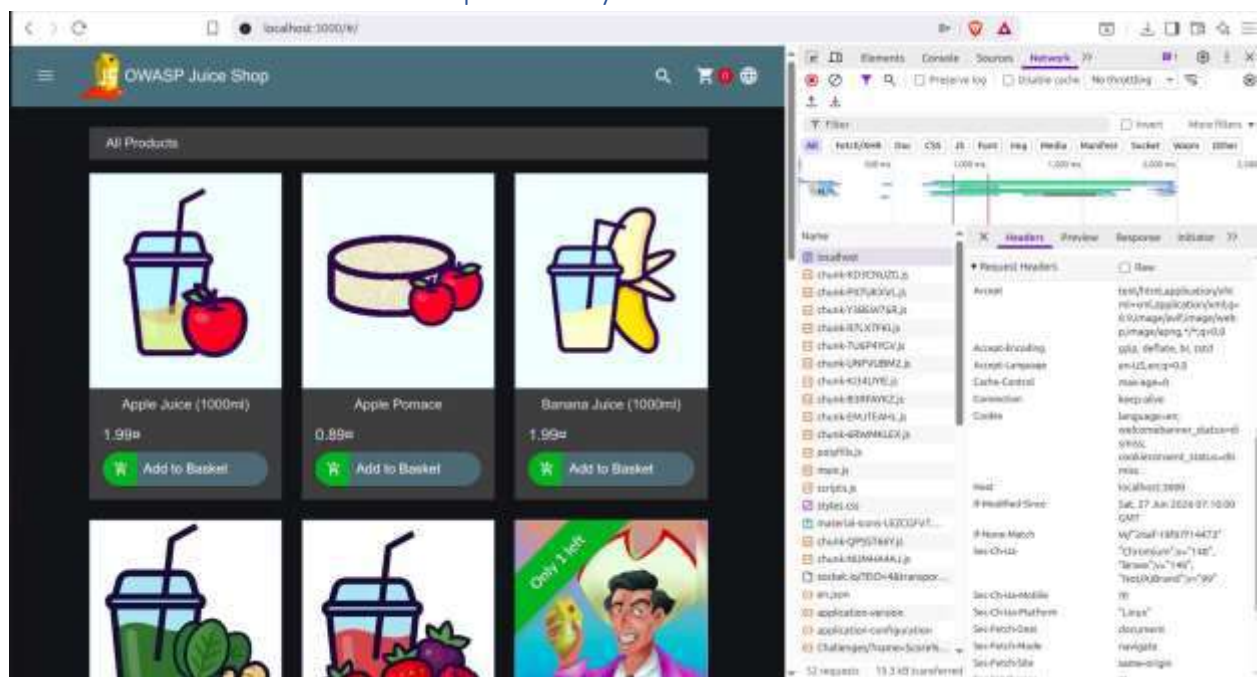


Figure 1: Request Headers

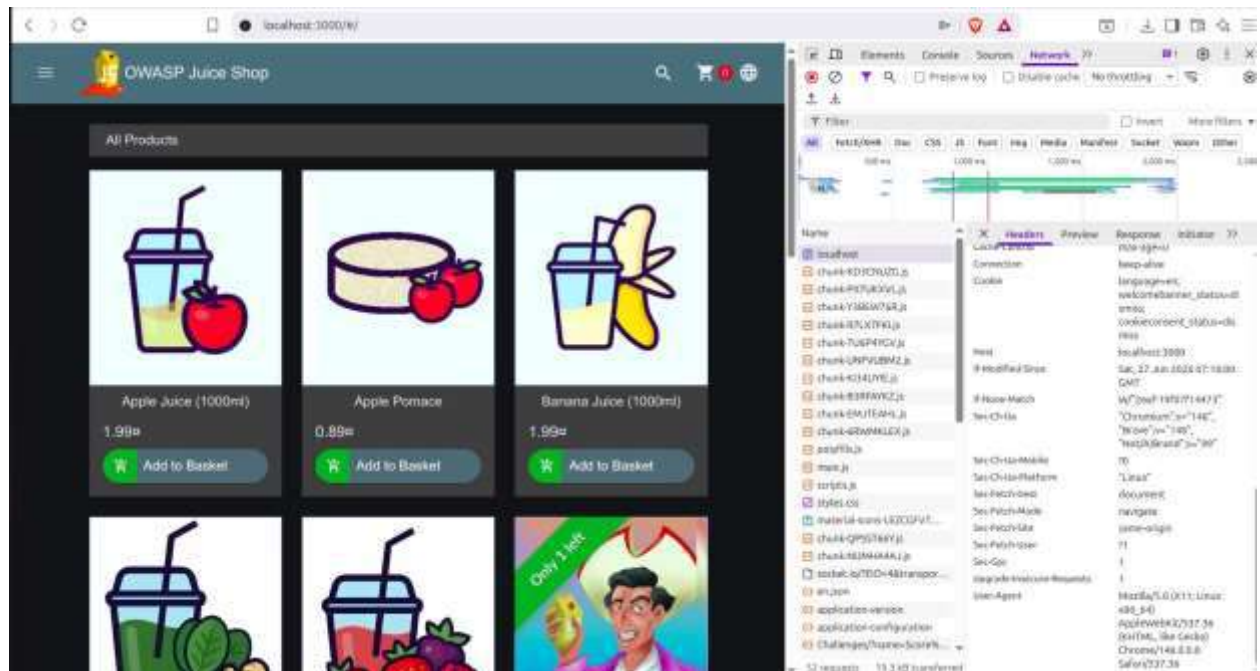


Figure 2: Request Headers 2

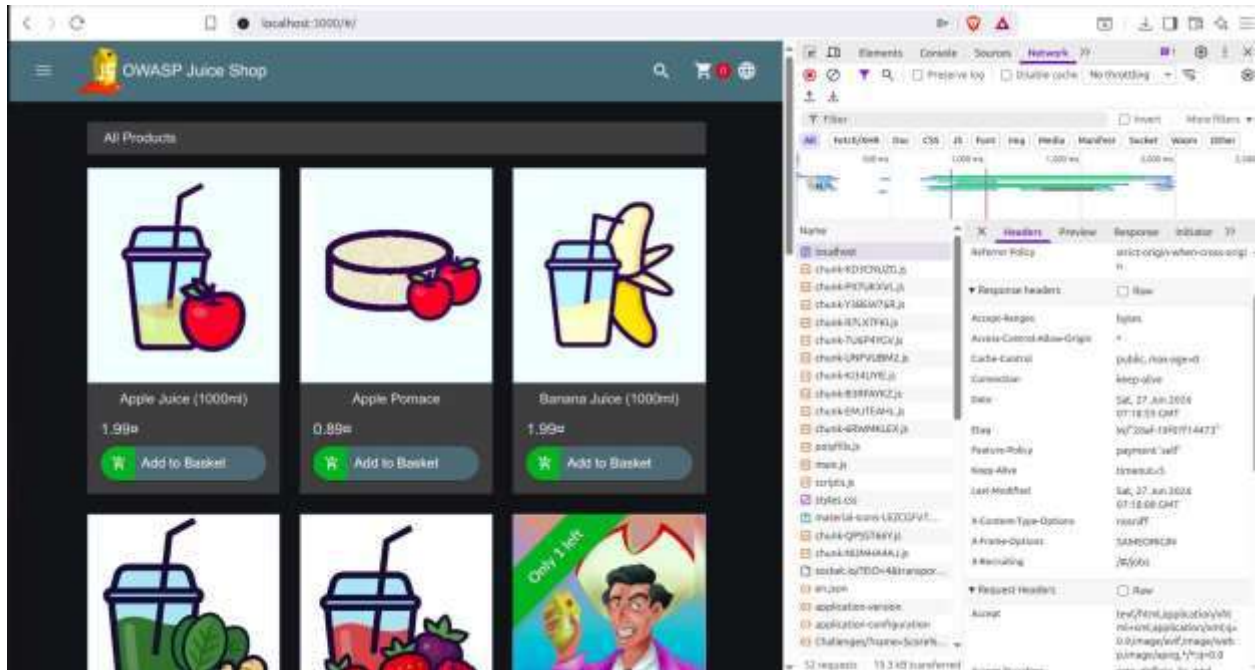


Figure 3: Response Headers

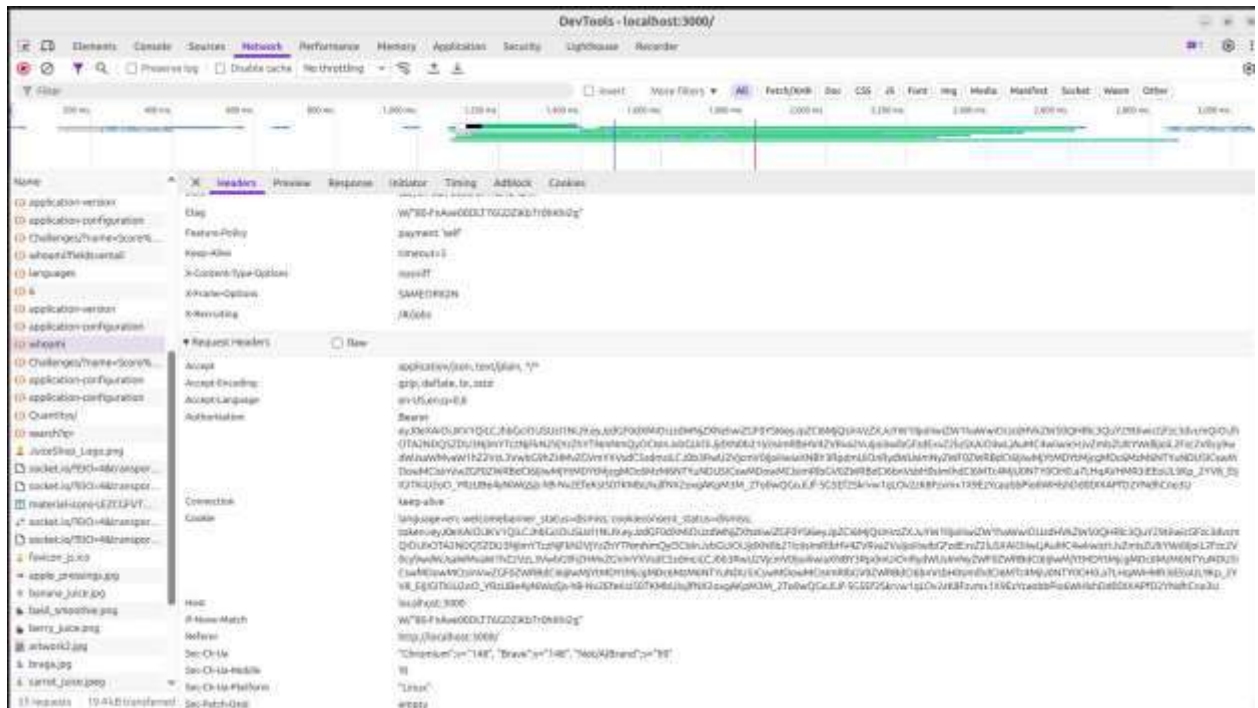


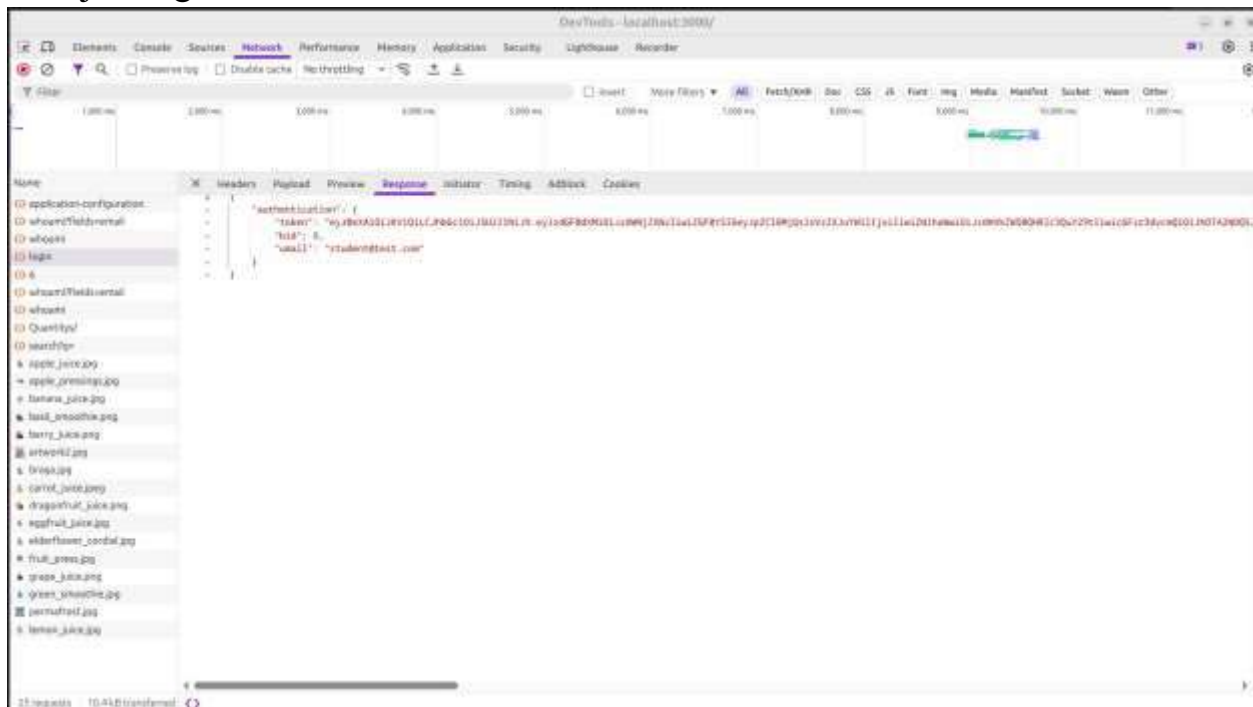
Figure 4: Authorization Mechanisms

Class Demonstration 2: Input Validation Testing

Test	Input	Result	Observation
Normal Search	apple	Products displayed	Search functionality worked correctly
Long Search	100+ letter a's	No result found	Application handled the long input without crashing or generating an error. Good input handling
Special characters	!@#\$%^&*()	No results	Application safely processed special characters without exposing errors or abnormal behavior
Invalid email	test	Rejected	Form required a properly formatted email address containing an @ symbol
Password policy	6+ character password	Accepted	Application enforced a minimum password length of 6 characters. Additional complexities i.e. uppercase optional

Class Demonstration 3: Cookie Security Analysis

During the login process, the application returned a JSON Web Token (JWT) after successful authentication. Network analysis showed that authentication is token based rather than relying solely on traditional session cookies. The response also included security headers such as X-Content-Type-Options: nosniff and X-Frame Options: SAMEORIGIN, which help protect against MIME-sniffing and clickjacking attacks.



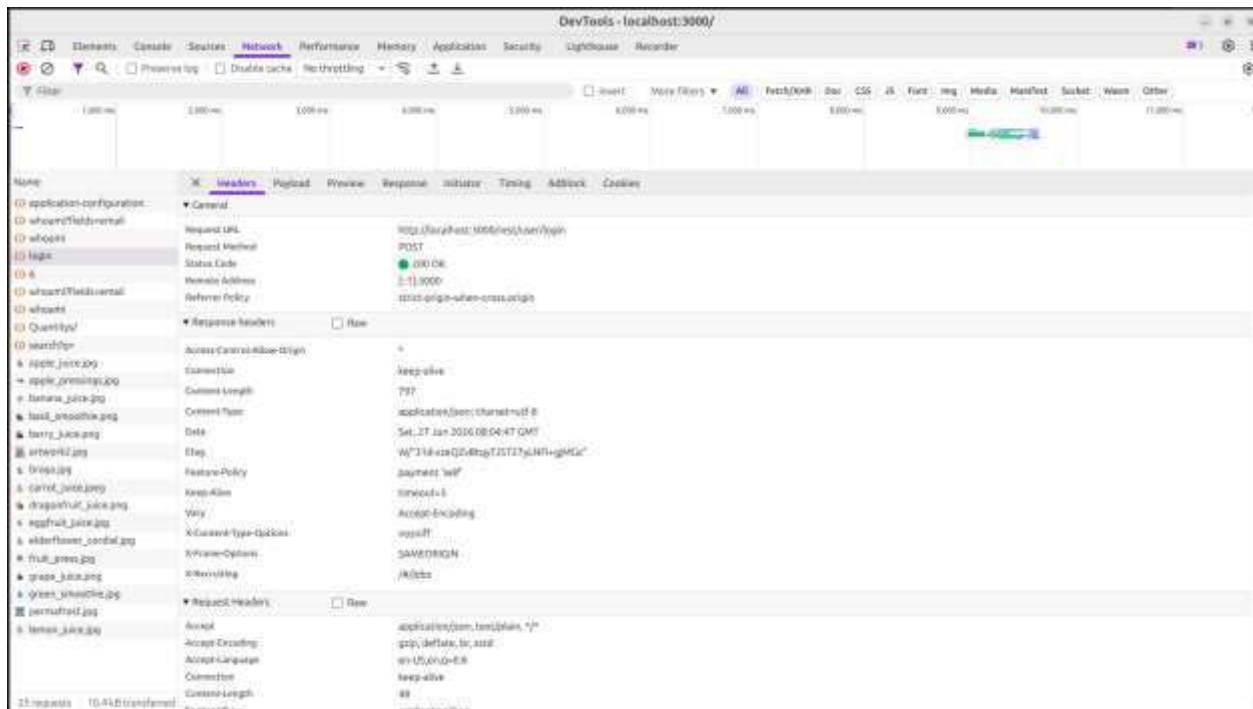


Figure 5: Login request analysis

Class Demonstration 4: Web Application Mapping

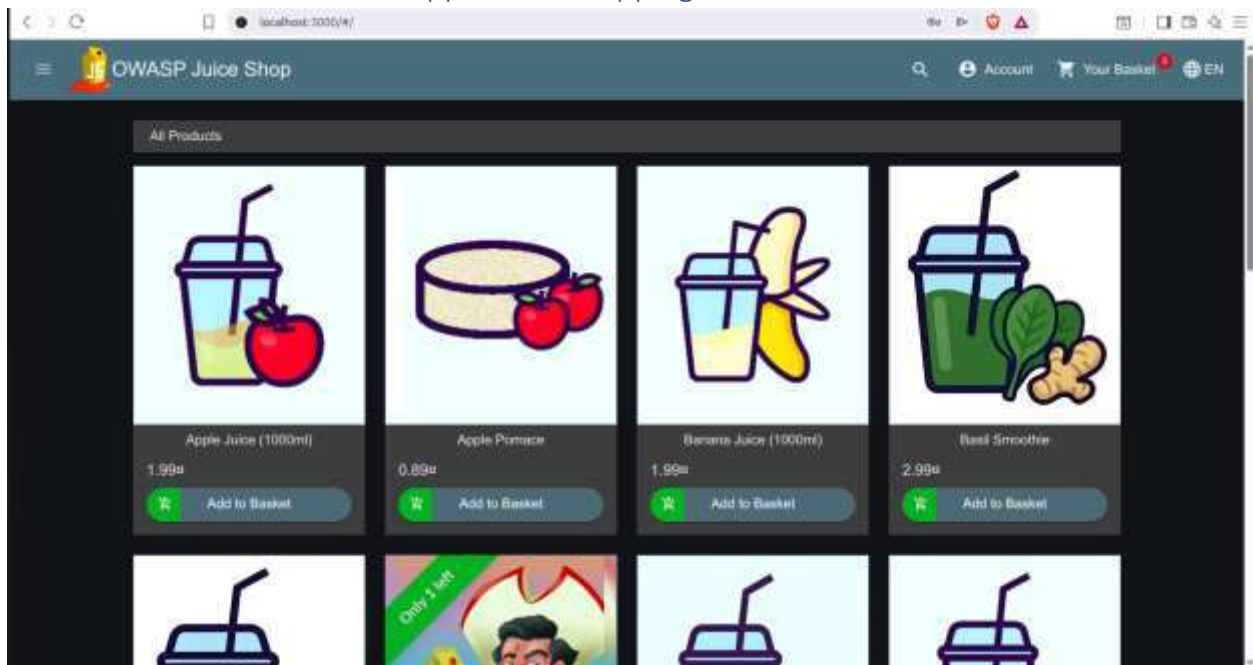


Figure 6: Home Page

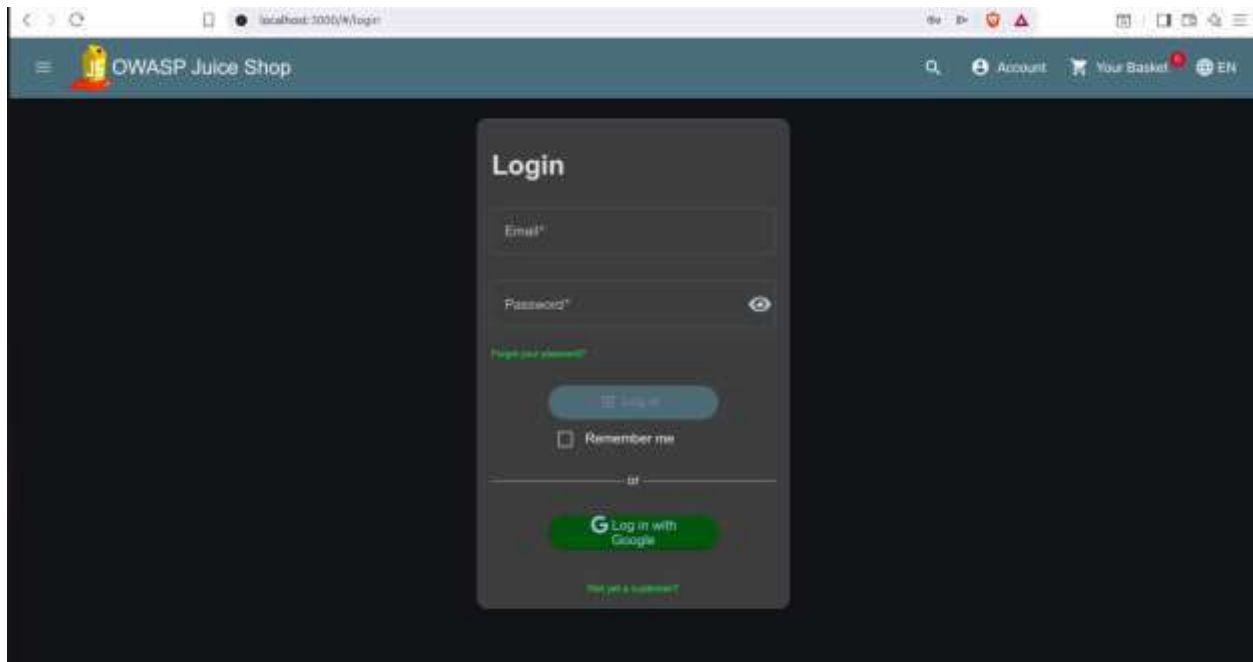


Figure 7: Login Page

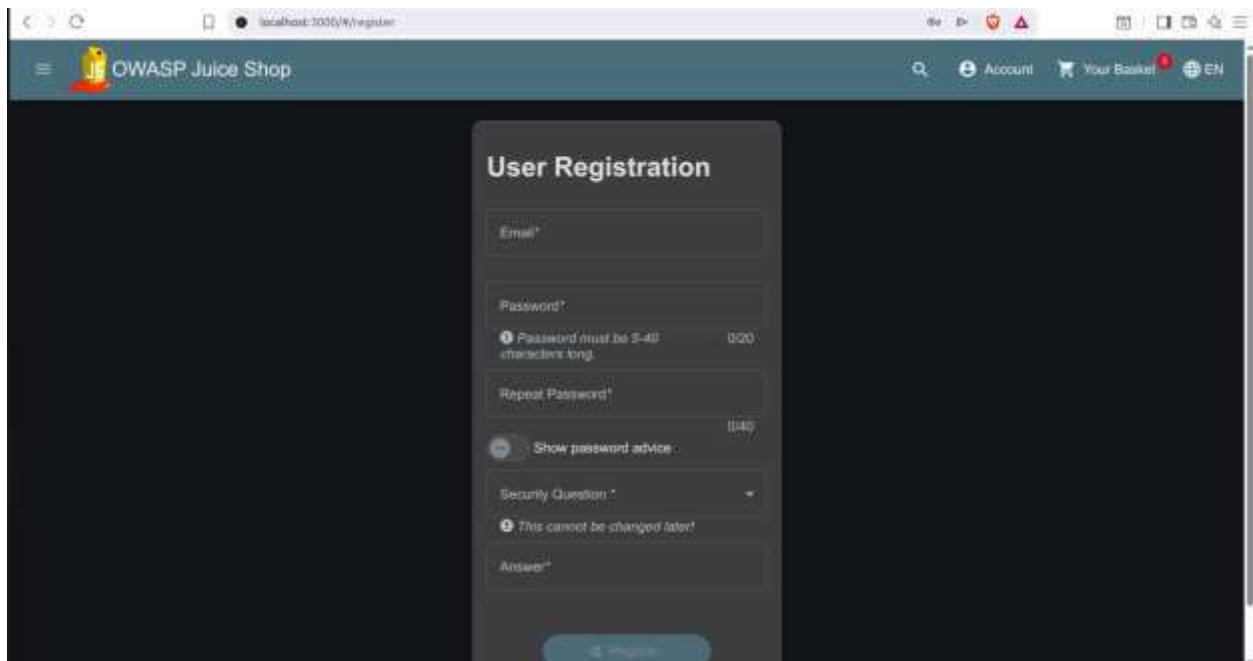


Figure 8: Registration Page

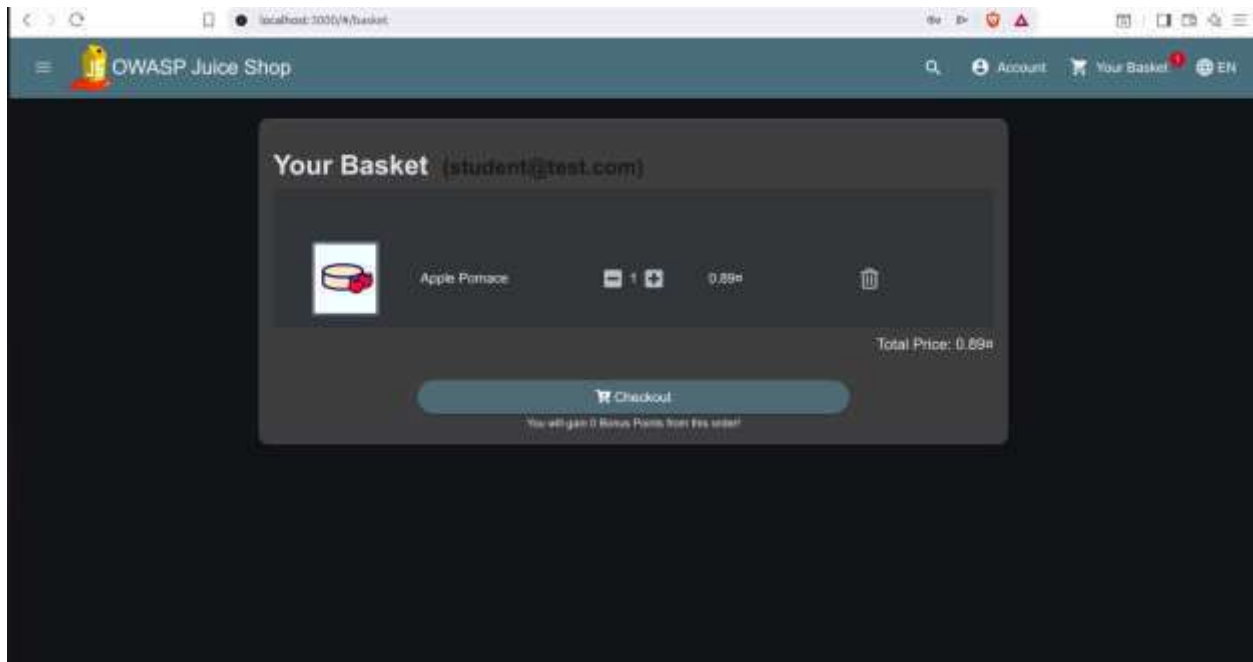


Figure 9: Basket

Class Activity 1: Vulnerability Identification Exercise

1. Authentication Findings

Strengths

- Email-based authentication.
- Registration process available.
- JWT token used after successful login.
- Authentication token successfully generated.

Weaknesses

- Minimum password length is only 5 characters
- No visible Multi-Factor Authentication
- No obvious account lockout after repeated failed logins.
- No visible CAPTCHA on the login page.

Risk Level: Medium

2. Input Validation

Tested the following:

- Long input
- Special characters
- Invalid email
- Password requirements

Results

The application:

- Handled long strings safely.
- Rejected invalid email formats.
- Did not crash when receiving special characters.
- Returned normal "No result found" messages.

Risk Level: Low

This suggests the application performs basic client and server-side validation.

3. Configuration Review

The following was observed

Good security headers:

- X-Content-Type-Options: nosniff
- X-Frame-Options: SAMEORIGIN

Potential concern:

- Access-Control-Allow-Origin: *

This header allows requests from any origin. Whether this is acceptable depends on the application's intended design. For a deliberately vulnerable training application like Juice Shop, this may be intentional. In a production system, it should be carefully reviewed to ensure sensitive APIs are not unnecessarily exposed.

Risk Level: Medium

Class Activity 2: Risk Classification

Issue	Risk	Justification
Weak Password Policy	Medium	Five character passwords are easier to brute-force than longer, more complex passwords
Missing MFA	Medium	User accounts rely only on passwords, increasing the impact of stolen credentials.
Missing Account Lockout	Medium	Unlimited login attempts can increase the risk of brute-force attacks.
Wildcard CORS (Access-Control-Allow-Origin:*)	Medium	Could expose APIs to unintended cross-origin requests if not carefully controlled
Input Validation	Low	The application safely handled invalid input during testing
Email Validation	Low	Invalid email addresses were correctly rejected.
Security Headers Present	Low	The observed headers improve protection against common browser-based attacks.

Class Activity 3: Secure Design Discussion

1. Why should security be built into applications?

Security should be considered from the beginning of the software development lifecycle because fixing vulnerabilities during design and development is easier and less expensive than addressing them after deployment. Early integration also reduces the risk of data breaches and security incidents.

2. What is the cost of fixing vulnerabilities late?

Late fixes often require code redesign, emergency patches, downtime, additional testing, and can lead to financial losses, reputational damage, and legal consequences if attackers exploit the vulnerabilities before they are resolved.

3. What is the role of developers in cybersecurity?

Developers play a key role by writing secure code, validating user input, implementing proper authentication and authorization, applying security updates, and following secure coding practices to reduce vulnerabilities in applications.

[Practical Task 1: OWASP Top 10 Research](#)

OWASP Vulnerability	Definition	Example	Impact	Prevention
Broken access control	Occurs when role users can access resources or perform actions beyond their permissions	A normal user can access an administrator page by changing the URL	Unauthorized access, privilege escalation and data theft	Implement role based access control, authorization checks and the principle of least privilege
Cryptographic failures	Sensitive information is not adequately protected	Password stored in plain text or data transmitted	Data breaches, identity theft and loss of confidentiality	Use strong encryption, HTTPS, secure key management, and hash

	through encryption	over plain HTTP		passwords with modern algorithms.
Injection	Untrusted user input is interpreted as commands by a database or operating system	SQL Injection in a login form.	Database compromise, data loss and unauthorized access	Use prepared statements and input validation.
Insecure Design Security	An online weakness caused by poor application design rather than coding mistakes.	An online banking system without transaction approval for large transfers	Business logic abuse, fraud, and unauthorized actions	Apply secure by design principles, threat modeling, and security reviews.
Security misconfiguration	Incorrect or insecure system configurations expose vulnerabilities	Default passwords or exposed administrative interfaces.	System compromise and information disclosure.	Remove default settings, harden configurations and perform regular security audits
Vulnerable and Outdated Components	Using software components with known	Running an outdated content management	Exploitation of known flaws leading	Regularly update software, apply security

	security vulnerabilities .	system or library.	to system compromise.	patches and monitor dependencies.
Identification and Authentication Failures	Weak authentication or session management allows attackers to impersonate users.	Weak passwords or session hijacking.	Account takeover and unauthorized access.	Enforce strong password policies, enable MFA, and secure session management.
Software and Data Integrity Failures	Failure to verify the integrity of software or updates	Installing unsigned software updates or compromised third-party libraries.	Malware infection and supply chain attacks	Use code signing, integrity verification, and secure CI/CD pipelines
Security Logging and Monitoring Failures	Insufficient logging and monitoring delay the detection of attacks.	Failed login attempts are not recorded or monitored.	Undetected attacks and delayed incident response.	Implement centralized logging, real-time monitoring, and incident response procedures
Server-Side Request Forgery	A server is tricked into making requests to unintended	A web application fetches a URL supplied by a user	Exposure of internal systems, data leakage,	Validate user supplied URLs, restrict outbound

	internal or external resources.	without validation.	cloud service compromise.	requests, segment internal networks
--	---------------------------------	---------------------	---------------------------	-------------------------------------

Practical Task 2: Web Application Assessment

Target Application Details

Application	OWASP Juice Shop
URL	http://localhost:3000
Testing environment	Ubuntu 24.04
Tools Used	Brave Developer Tools, OWASP ZAP, Nikto

Identified Forms

Form	Purpose	Observation
Login	User authentication	Requires email and password
Registration	New account creation	Validates email format and password length
Search	Product search	Takes user input and returns matching products

Feedback	Customer feedback	Allows users to submit comments
Product Review	Product ratings and reviews	Available after login
Password Reset	Account recovery	Uses security question and answer

Authentication Mechanisms

Users authenticate using an email address and password.

Successful login returns a JSON Web Token (JWT).

The token is used to maintain the authenticated session.

No Multi-Factor Authentication (MFA) was observed.

No visible account lockout mechanism was observed.

User Roles

Guest- Can browse products without logging in

Registered User- Can purchase products, leave reviews and manage their account

Administrator- Section not accessible to normal users

Input Validation Findings

Long Input- Application remained stable and returned "No results found."

Special Characters- Safely handled without errors

Invalid Email- Rejected until a valid email format was entered

Password- Minimum length of five characters enforced

Basic input validation is implemented and no abnormal behavior was observed during testing.

Potential Vulnerabilities

Observation	Risk	Recommendation
Minimum password length only	Medium	Require stronger passwords (8–12+ characters with complexity rules).
No visible MFA	Medium	Implement multi-factor authentication for enhanced account security.
No visible account logout	Medium	Introduce temporary account logout or rate limiting after repeated failed login attempts.
Wildcard CORS (Access-Control-Allow-Origin: *)	Medium	Restrict allowed origins where appropriate in production environments.

Practical Task 3: Security Improvement Proposal

Title: Security Improvement Proposal for OWASP Juice Shop

1. Introduction

This proposal presents recommendations to improve the security of the OWASP Juice Shop web application. The recommendations are based on observations made during the web application assessment using browser developer tools, OWASP ZAP, and Nikto. The objective is to reduce security risks, strengthen user account protection and improve the application's overall security posture.

2. Identified Security Issues

The following issues were identified during the assessment:

Issue	Risk Level
Weak password policy	Medium
No Multi-Factor Authentication	Medium
No visible account lockout after repeated failed logins	Medium
Cross-Origin Resource Sharing configured with Access-Control-Allow-	Medium
Origin: *	

3. Proposed Security Improvements

Recommendation 1: Strengthen the Password Policy Current Observation

The application accepts passwords with a minimum length of six characters.

Recommendation

Require users to create passwords that:

- Are at least 8–12 characters long.
- Include uppercase and lowercase letters.
- Include numbers.
- Include special characters.

Benefit

Stronger passwords reduce the risk of brute-force and dictionary attacks.

Recommendation 2: Implement Multi-Factor Authentication Current Observation

Authentication relies solely on an email address and password.

Recommendation

Implement MFA using:

- Authentication apps (recommended), or
- Email verification codes, or
- SMS verification where appropriate.

Benefit

Even if a password is compromised, unauthorized users cannot easily access the account.

Recommendation 3: Implement Account Lockout and Rate Limiting Current Observation

No account lockout mechanism was observed during testing.

Recommendation

- Lock an account temporarily after several failed login attempts.
- Apply rate limiting to login requests.

Benefit

This helps prevent automated brute-force attacks.

Recommendation 4: Restrict Cross-Origin Resource Sharing (CORS)

Current Observation

The response header: Access-Control-Allow-Origin: * was observed during testing.

Recommendation

Restrict allowed origins to trusted domains instead of allowing all origins.

Benefit

Reduces the risk of unauthorized websites interacting with the application's resources.

Recommendation 5: Improve Logging and Monitoring Recommendation

Implement centralized logging to record:

- Failed login attempts
- Administrative actions
- Authentication events
- Suspicious requests

Configure alerts for unusual activities.

Benefit

Improves incident detection and supports forensic investigations.

Recommendation 6: Regular Security Testing Recommendation

Perform regular:

- Vulnerability assessments
- Penetration testing
- Security code reviews
- Dependency updates using tools such as:
 - OWASP ZAP
 - Nikto
 - Nmap

Benefit

Helps identify and remediate vulnerabilities before they can be exploited.

4. Expected Benefits

Implementing these recommendations will:

- Improve user account protection.
- Reduce the likelihood of unauthorized access.
- Strengthen authentication mechanisms.
- Improve compliance with secure development practices.
- Reduce exposure to common web application attacks.

5. Conclusion

The assessment demonstrated that OWASP Juice Shop includes several important security features, including JWT-based authentication, input validation, and protective HTTP security headers. However, improvements such as stronger password policies, multi-factor authentication, account lockout mechanisms, improved logging, would further strengthen the application's security and reduce potential risks.